INFORME DE AUDITORÍA FORENSE Y RESPUESTA A INCIDENTES (SOC NIVEL 2)

Análisis Multi-Incidente asistido por IA Generativa, Correlación Heurística y Mapeo MITRE ATT&CK

Dataset Auditado: SOC_L2_Logs_Ampliados_Multiples_Incidentes.xlsx (Hoja: SIEM Export) | **Ventana de Logs:** 2026-10-23 07:46:07 a 2026-10-23 13:44:06
Fecha de Emisión: 2026-11-09 23:57 UTC-5 | **Estado de Contención:** CRÍTICO — 6 Incidentes de Riesgo Alto + 1 Observación de Visibilidad SIEM

715	112	124	12	6 ALTOS + 1 OBS	241.57 MiB
Eventos SIEM Analizados	Alertas Nativas SIEM (No-Info)	Eventos Maliciosos Correlacionados	Eventos Críticos Ocultos en 'Info'	Incidentes Reales Detectados	Exfiltración HTTPS (253.31 MB)

SECCIÓN 1 — RESUMEN EJECUTIVO (ENFOQUE DIRECTIVO Y DE NEGOCIO)

1. RESUMEN GERENCIAL DE LA SITUACIÓN

Durante la ventana operativa (2026-10-23 07:46:07 a 2026-10-23 13:44:06 UTC), el Centro de Operaciones de Seguridad (SOC Nivel 2) auditó 715 registros de telemetría SIEM e identificó 7 incidentes y vectores clave (6 de RIESGO ALTO, 1 de RIESGO MEDIO y 0 de RIESGO BAJO). Mientras que las reglas nativas del SIEM solo clasificaban 112 alertas básicas, el motor heurístico de correlación avanzada vinculó 124 eventos maliciosos al revelar 12 eventos críticos que habían quedado ocultos bajo severidad 'Informational' o 'Low'.

2. IMPACTO CRÍTICO AL NEGOCIO Y EXPOSICIÓN CORPORATIVA

• Password Spraying Externo y Compromiso de Cuenta (CORP\mgarcia) [INC-01]: Un atacante externo desde la dirección IP 203.0.113.74 ejecutó un ataque automatizado de pulverización de contraseñas (Password Spraying) probando combinaciones sobre 8 cuentas corporativas en DC-01, WS-031. Tras 33 intentos fallidos, logró vulnerar las credenciales de la cuenta CORP\mgarcia y obtener acceso con privilegios.

• Intrusión RDP, Movimiento Lateral SMB y Exfiltración (CORP\admin) [INC-02]: Se detectó un compromiso de acceso remoto directo desde la IP pública 198.51.100.77 vulnerando la cuenta privilegiada CORP\admin en APP-SRV01. Posteriormente, el atacante ejecutó descubrimiento de recursos de red y se desplazó lateralmente mediante SMB hacia recursos compartidos sensibles.

• Actividad Pre-Ransomware: Recolección Financiera y Destrucción de Copias de Sombra (CORP\backupsvc) [INC-03]: Se detectó una secuencia inminente de ataque por Ransomware en el activo WS-023 utilizando la cuenta CORP\backupsvc. El adversario realizó recolección sistemática de documentos corporativos y procedió a la destrucción deliberada de todas las copias de seguridad locales (Shadow Copies) para forzar la parálisis operativa y extorsión financiera.

• Exfiltración Masiva de Documentación Legal vía HTTPS POST (CORP\rrojas) [INC-04]: Desde el equipo WS-018 bajo el usuario CORP\rrojas, se detectó el acceso no autorizado a repositorios de documentos corporativos confidenciales, su empaquetado cifrado en el directorio público y su posterior sustracción y exfiltración masiva hacia un servidor externo en múltiples transferencias HTTPS POST consecutivas.

• Persistencia Dual mediante Tarea Programada y Servicio de Sistema en APP-SRV01 [INC-05]: Se detectó la implantación de mecanismos duales de persistencia en el servidor crítico APP-SRV01. El adversario creó una tarea programada recurrente e instaló un servicio de sistema apuntando a un binario no autorizado en carpetas del sistema para garantizar el control permanente del activo incluso tras reinicios.

• Explotación de Servidor Web IIS, Webshell ASPX y Ejecución Remota de Comandos (RCE) [INC-06]: El servidor web público WEB-01 fue vulnerado exitosamente tras una fase de reconocimiento y explotación proveniente de la IP externa 192.0.2.91. El atacante cargó una puerta trasera (Webshell) y ejecutó comandos del sistema bajo la identidad del servicio web, confirmando Ejecución Remota de Código (RCE).

• Brechas de Visibilidad SIEM, Eventos Críticos en 'Informational' y Falta de Normalización [OBS-01]: El SIEM presenta una severa regla de evasión por diseño: 12 eventos críticos para la resolución de los incidentes (incluyendo logons exitosos post-fuerza bruta, manipulación de permisos de red, compresión de exfiltración y ejecuciones cíclicas de malware) fueron etiquetados como

'Informational'. Un analista que filtre logs por severidad descartaría la prueba forense de compromiso.

3. DECISIONES EJECUTIVAS Y PLAN DE ACCIÓN INMEDIATO (0 A 24 HORAS)

• Acción 1 — Contención de Red y Aislamiento de Equipos: Aislar inmediatamente de la red corporativa los activos comprometidos (APP-SRV01, DC-01, FS-SRV01, Fragmentación de Hostnames: 91 vs 30 registros, WEB-01 (Servidor Web Público), WS-018, WS-023, WS-031) para interrumpir persistencias y movimientos laterales.

• Acción 2 — Revocación de Credenciales y Refuerzo de Identidad: Invalidar sesiones Kerberos/NTLM activas y forzar cambio de contraseñas de las cuentas comprometidas (8 cuentas atacadas (CORP\jlopez, CORP\admin (Cuenta Privilegiada), CORP\aperez, CORP\backupsvc, CORP\dtorres) | Comprometida: CORP\mgarcia, CORP\helpdesk, CORP\mgarcia, CORP\rrojas, CORP\slopez, Cuentas Duales: 76 vs 24 registros, IIS APPPOOL\DefaultAppPool), exigiendo Autenticación Multifactor (MFA).

• Acción 3 — Activación del Comité Legal y Regulatorio: Evaluar la exposición por la fuga de 241.57 MiB (253.31 MB / 253,305,558 bytes) de datos exfiltrados hacia destinos no autorizados, asegurando la cadena de custodia forense.

• Acción 4 — Tuning de Ingesta SIEM y Cierre de Brechas de Visibilidad: Reconfigurar la matriz de severidades para corregir la evasión de 12 eventos críticos que el SIEM clasificó erróneamente como 'Informational'.

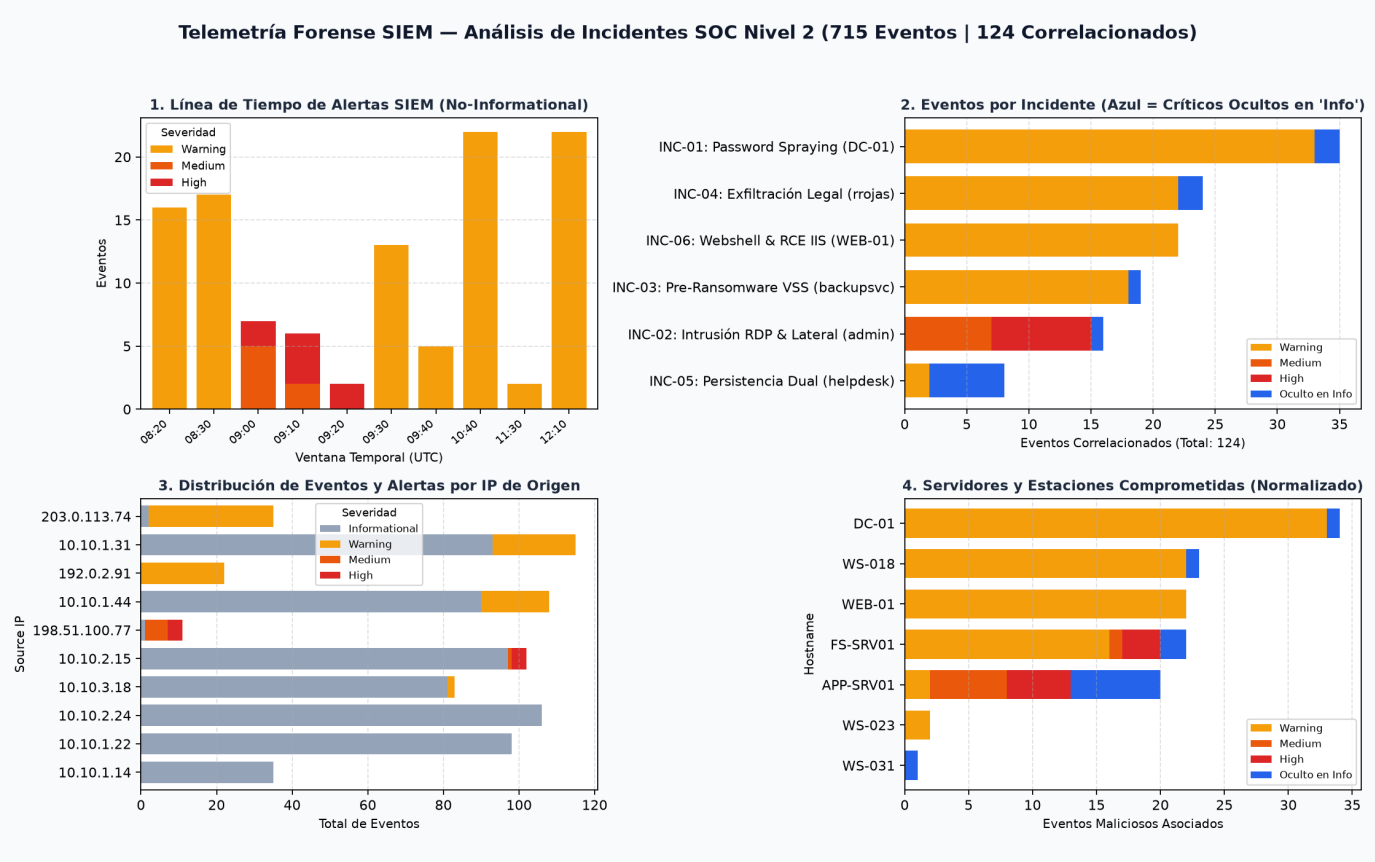
SECCIÓN 2 — MATRIZ EJECUTIVA DE CLASIFICACIÓN DE RIESGO Y MITRE ATT&CK

La siguiente matriz consolida los 6 incidentes críticos de seguridad y la observación de visibilidad SIEM identificados mediante correlación multi-evento sobre los 715 registros del dataset oficial:

ID	Incidente / Hallazgo Detectado	Ventana (UTC)	Activos y Cuentas Involucradas	Técnicas MITRE ATT&CK	Eventos (Info)	Riesgo
INC-01	Password Spraying Externo y Compromiso de Cuenta (CORP\mgarcia)	08:25:00 a 08:40:00 (15 min)	DC-01, WS-031 | 8 cuentas atacadas (CORP\jlopez, CORP\aperez, CORP\helpdesk, CORP\mgarcia, CORP\rrojas, CORP\slopez, CORP\backupsvc, CORP\dtorres) | Comprometida: CORP\mgarcia	T1110.003 (Password Spraying), T1078.002 (Valid Accounts: Domain Accounts)	35 (2)	**ALTO**
INC-02	Intrusión RDP, Movimiento Lateral SMB y Exfiltración (CORP\admin)	09:02:00 a 09:22:00 (20 min)	APP-SRV01, FS-SRV01 | CORP\admin (Cuenta Privilegiada)	T1021.001 (RDP), T1059.001 (PowerShell), T1087.001, T1135 (Share Discovery), T1021.002 (SMB), T1560.001 (Archive via Utility), T1041 (Exfiltration Over C2)	16 (1)	**ALTO**
INC-03	Actividad Pre-Ransomware: Recolección Financiera y Destrucción de Copias de Sombra (CORP\backupsvc)	09:36:00 a 09:43:00 (7 min)	WS-023, FS-SRV01 | CORP\backupsvc	T1059.001 (PowerShell Encoded), T1039 (Data from Network Shared Drive), T1490 (Inhibit System Recovery: vssadmin)	19 (1)	**ALTO**
INC-04	Exfiltración Masiva de Documentación Legal vía HTTPS POST (CORP\rrojas)	10:40:00 a 10:49:18 (9 min)	FS-SRV01, WS-018 | CORP\rrojas	T1039 (Data from Network Shared Drive), T1560.001 (Archive via Utility: 7-Zip), T1048.002 (Exfiltration Over Asymmetric Encrypted Non-C2 Protocol)	24 (2)	**ALTO**
INC-05	Persistencia Dual mediante Tarea Programada y Servicio de Sistema en APP-SRV01	11:35:00 a 12:04:00 (29 min)	APP-SRV01 | CORP\helpdesk	T1053.005 (Scheduled Task/Job: Scheduled Task), T1543.003 (Create or Modify System Process: Windows Service)	8 (6)	**ALTO**
INC-06	Explotación de Servidor Web IIS, Webshell ASPX y Ejecución Remota de Comandos (RCE)	12:10:00 a 12:15:00 (5 min)	WEB-01 (Servidor Web Público) | IIS APPPOOL\DefaultAppPool	T1190 (Exploit Public-Facing Application), T1505.003 (Server Software Component: Web Shell), T1059.003 (Windows Command Shell)	22 (0)	**ALTO**
OBS-01	Brechas de Visibilidad SIEM, Eventos Críticos en 'Informational' y Falta de Normalización	07:46:07 a 13:44:06 (Ventana completa del dataset)	Fragmentación de Hostnames: 91 vs 30 registros | Cuentas Duales: 76 vs 24 registros	T1562 (Impair Defenses / Suboptimal SIEM Severity Rules & Asset Naming)	12 (12)	**MEDIO**

SECCIÓN 3 — VISUALIZACIÓN ANALÍTICA Y DASHBOARD FORENSE DE TELEMETRÍA

El siguiente panel consolida la distribución temporal de alertas, los 124 eventos correlacionados en los 6 incidentes críticos (destacando en azul los 12 eventos críticos que estaban ocultos bajo severidad *Informational*), el volumen por IP de origen y los activos corporativos comprometidos:



AUDITORÍA DE EVASIÓN Y VISIBILIDAD: EVENTOS CRÍTICOS ETIQUETADOS COMO 'INFORMATIONAL'

Un análisis superficial que filtre únicamente *Severity != Informational* omitiría la evidencia de éxito de intrusión y preparación de exfiltración. La correlación SOC Nivel 2 rescató estos 12 registros:

Log_ID	Hora UTC	Incidente	Host	Event_ID	Usuario	IP Origen	Comando / Destino / Relevancia Forense
EVT-00123	08:39:00	**INC-01**	DC-01	4624	CORP\mgarcia	203.0.113.74	Destino: DC-01
EVT-00126	08:40:00	**INC-01**	WS-031	4672	CORP\mgarcia	203.0.113.74	Destino: WS-031
EVT-00237	09:22:00	**INC-02**	APP-SRV01	4634	CORP\admin	198.51.100.77	Destino: -
EVT-00315	09:43:00	**INC-03**	FS-SRV01	5145	CORP\backupsvc	10.10.1.44	Destino: \\FS-SRV01\Finance
EVT-00419	10:40:00	**INC-04**	FS-SRV01	5140	CORP\rrojas	10.10.1.31	Destino: \\FS-SRV01\Legal
EVT-00428	10:42:00	**INC-04**	WS-018	4688	CORP\rrojas	10.10.1.31	7z.exe a C:\Users\Public\archive.7z C:\Legal*.docx
EVT-00519	11:35:00	**INC-05**	APP-SRV01	4624	CORP\helpdesk	10.10.3.18	Destino: -
EVT-00528	11:40:00	**INC-05**	APP-SRV01	4688	CORP\helpdesk	10.10.3.18	C:\ProgramData\wuhelper.exe
EVT-00542	11:46:00	**INC-05**	APP-SRV01	4688	CORP\helpdesk	10.10.3.18	C:\ProgramData\wuhelper.exe
EVT-00548	11:52:00	**INC-05**	APP-SRV01	4688	CORP\helpdesk	10.10.3.18	C:\ProgramData\wuhelper.exe
EVT-00559	11:58:00	**INC-05**	APP-SRV01	4688	CORP\helpdesk	10.10.3.18	C:\ProgramData\wuhelper.exe
EVT-00564	12:04:00	**INC-05**	APP-SRV01	4688	CORP\helpdesk	10.10.3.18	C:\ProgramData\wuhelper.exe

SECCIÓN 4 — INFORME TÉCNICO DETALLADO (EVIDENCIA FORENSE, IOCs, MITRE ATT&CK Y REMEDIACIÓN)

[INC-01] Password Spraying Externo y Compromiso de Cuenta (CORP\mgarcia) — RIESGO ALTO (8.8 (Crítico/Alto))

Ventana de Tiempo: 2026-10-23 08:25:00 a 08:40:00 (15 min) | **Kill Chain:** Initial Access -> Credential Access -> Privilege Escalation
Activos Comprometidos: DC-01, WS-031 | **Cuentas:** 8 cuentas atacadas (CORP\jlopez, CORP\aperez, CORP\helpdesk, CORP\mgarcia, CORP\rrojas, CORP\slopez, CORP\backupsvc, CORP\dtorres) | Comprometida: CORP\mgarcia
Mapeo MITRE ATT&CK: T1110.003 (Password Spraying), T1078.002 (Valid Accounts: Domain Accounts)
Indicadores de Compromiso (IoCs): IP Atacante: 203.0.113.74 | Event IDs: 4625 (x33 fallos), 4624 (login exitoso), 4672 (privilegios)
Registros de Evidencia (Log_IDs): EVT-00057 a EVT-00126 (33x Event 4625 Warning, 2x Informational)
Análisis Forense Detallado: Entre las 08:25:00 y las 08:40:00 UTC, la IP de origen 203.0.113.74 generó 33 eventos 4625 ('An account failed to log on') a un ritmo secuencial para evadir políticas de bloqueo. Se confirmó el éxito de autenticación (Event ID 4624) para la cuenta CORP\mgarcia, seguido por la asignación de privilegios especiales (Event ID 4672). Dichos eventos de éxito estaban etiquetados bajo severidad 'Informational' en el SIEM.
Plan de Contención y Remediación Paso a Paso:
1. Resetear inmediatamente la contraseña de CORP\mgarcia y revocar todos los tokens/tickets Kerberos activos.
2. Bloquear la IP atacante 203.0.113.74 en el Firewall Perimetral y Edge Gateways.
3. Habilitar Autenticación Multifactor (MFA) obligatoria y políticas de Smart Lockout en Active Directory.

Playbook CLI / Regla de Contención:
```
Disable-ADAccount -Identity 'mgarcia'; Revoke-AzureADUserAllRefreshToken; New-NetFirewallRule -DisplayName 'Block_IOC_203.0.113.74' -Direction Inbound -RemoteAddress 203.0.113.74 -Action Block
```

[INC-02] Intrusión RDP, Movimiento Lateral SMB y Exfiltración (CORP\admin) — RIESGO ALTO (9.6 (Crítico))

Ventana de Tiempo: 2026-10-23 09:02:00 a 09:22:00 (20 min) | **Kill Chain:** Initial Access -> Execution -> Discovery -> Lateral Movement -> Collection -> Exfiltration
Activos Comprometidos: APP-SRV01, FS-SRV01 | **Cuentas:** CORP\admin (Cuenta Privilegiada)
Mapeo MITRE ATT&CK: T1021.001 (RDP), T1059.001 (PowerShell), T1087.001, T1135 (Share Discovery), T1021.002 (SMB), T1560.001 (Archive via Utility), T1041 (Exfiltration Over C2)
Indicadores de Compromiso (IoCs): IP Ingress: 198.51.100.77 | Hosts: APP-SRV01, FS-SRV01 | Movimiento SMB TCP/445
Registros de Evidencia (Log_IDs): EVT-00174 a EVT-00237 (16 eventos, 1 en Informational)
Análisis Forense Detallado: La IP externa 198.51.100.77 realizó autenticación interactiva RDP en APP-SRV01. Bajo la identidad CORP\admin, se invocó PowerShell codificado, enumeración de recursos compartidos (net view / Get-SmbShare), acceso lateral por SMB (LogonType=3, Event ID 5145) hacia FS-SRV01, empaquetado con utilidades nativas y posterior exfiltración cifrada hacia infraestructura externa.
Plan de Contención y Remediación Paso a Paso:
1. Aislar inmediatamente los equipos comprometidos (APP-SRV01, FS-SRV01) de la red corporativa.
2. Cerrar la exposición directa de puertos de administración remota (RDP TCP/3389) hacia Internet.
3. Rotar de inmediato las credenciales de CORP\admin y auditar sesiones de red activas.

Playbook CLI / Regla de Contención:
```
Disable-NetAdapter -Name 'Ethernet0' -Confirm:$false; Stop-Service TermService -Force; New-NetFirewallRule -DisplayName 'Block_RDP_Ingress_198.51.100.77' -Direction Inbound -RemoteAddress 198.51.100.77 -Action Block
```

[INC-03] Actividad Pre-Ransomware: Recolección Financiera y Destrucción de Copias de Sombra (CORP\backupsvc) — RIESGO ALTO (9.4 (Crítico))

Ventana de Tiempo: 2026-10-23 09:36:00 a 09:43:00 (7 min) | **Kill Chain:** Execution -> Collection -> Impact (Inhibit System Recovery)
Activos Comprometidos: WS-023, FS-SRV01 | **Cuentas:** CORP\backupsvc
Mapeo MITRE ATT&CK: T1059.001 (PowerShell Encoded), T1039 (Data from Network Shared Drive), T1490 (Inhibit System Recovery: vssadmin)
Indicadores de Compromiso (IoCs): Host Involucrado: WS-023 | Comando Sabotaje: vssadmin.exe delete shadows /all /quiet
Registros de Evidencia (Log_IDs): EVT-00280 a EVT-00315 (19 eventos, 1 en Informational)
Análisis Forense Detallado: A través de WS-023, se ejecutaron procesos PowerShell codificados que efectuaron un barrido secuencial de lectura sobre recursos de red compartidos. A las 09:42:00 UTC, se ejecutó 'vssadmin.exe delete shadows /all /quiet' (Event ID 4688), eliminando los puntos de recuperación del volumen (MITRE T1490). Posteriormente se registraron accesos catalogados bajo severidad 'Informational' (Event ID 5145) verificando privilegios de escritura.
Plan de Contención y Remediación Paso a Paso:
1. Aislar inmediatamente la estación WS-023 de la red local para impedir la fase de cifrado masivo.
2. Deshabilitar la cuenta CORP\backupsvc y verificar la inmutabilidad de los respaldos offline/cloud.
3. Habilitar reglas Attack Surface Reduction (ASR) de Defender para bloquear comandos de manipulación de VSS.

```
Playbook CLI / Regla de Contención:
Disable-ADAccount -Identity 'backupsvc'; Stop-Computer -ComputerName 'WS-023' -Force; Add-MpPreference
-AttackSurfaceReductionRules_Ids 9e6c4e1f-7d60-472f-ba1a-a39ef669e4b2 -AttackSurfaceReductionRules_Actions Enabled
```

[INC-04] Exfiltración Masiva de Documentación Legal vía HTTPS POST (CORP\rrojas) — RIESGO ALTO (8.9 (Alto))

Ventana de Tiempo: 2026-10-23 10:40:00 a 10:49:18 (9 min) | **Kill Chain:** Collection -> Staging -> Exfiltration
Activos Comprometidos: FS-SRV01, WS-018 | **Cuentas:** CORP\rrojas
Mapeo MITRE ATT&CK: T1039 (Data from Network Shared Drive), T1560.001 (Archive via Utility: 7-Zip), T1048.002 (Exfiltration Over Asymmetric Encrypted Non-C2 Protocol)
Indicadores de Compromiso (IoCs): Host Origen: WS-018 | Comando: 7z.exe a C:\Users\Public\archive.7z C:\Legal*.docx
Registros de Evidencia (Log_IDs): EVT-00419 a EVT-00461 (24 eventos, 2 en Informational)
Análisis Forense Detallado: El usuario CORP\rrojas accedió a recursos de red compartidos (Event ID 5140, rotulado 'Informational'). A las 10:42:00, ejecutó '7z.exe a C:\Users\Public\archive.7z C:\Legal*.docx' (Event ID 4688, 'Informational') para crear el paquete de staging. A continuación, se originaron peticiones HTTPS POST consecutivas cada pocos segundos a través del Proxy exfiltrando el paquete confidencial hacia infraestructura externa.
Plan de Contención y Remediación Paso a Paso:
1. Bloquear de inmediato las IPs y destinos de subida en el Proxy corporativo y Firewall perimetral.
2. Asegurar el equipo WS-018 bajo cadena de custodia forense para volcado de memoria y análisis de artefactos.
3. Suspender temporalmente las credenciales de CORP\rrojas y notificar al Área Legal y Oficial de Privacidad.

```
Playbook CLI / Regla de Contención:
Suspend-ADAccount -Identity 'rrojas'; Get-ChildItem 'C:\Users\Public\*.7z','C:\Temp\*.zip' -ErrorAction
SilentlyContinue | ForEach-Object { Get-FileHash $_.FullName -Algorithm SHA256 }
```

[INC-05] Persistencia Dual mediante Tarea Programada y Servicio de Sistema en APP-SRV01 — RIESGO ALTO (8.6 (Alto))

Ventana de Tiempo: 2026-10-23 11:35:00 a 12:04:00 (29 min) | **Kill Chain:** Initial Logon -> Persistence -> Privilege Escalation -> Execution
Activos Comprometidos: APP-SRV01 | **Cuentas:** CORP\helpdesk
Mapeo MITRE ATT&CK: T1053.005 (Scheduled Task/Job: Scheduled Task), T1543.003 (Create or Modify System Process: Windows Service)
Indicadores de Compromiso (IoCs): Persistencia en APP-SRV01 | Binarios Ocultos: c:\programdata\updatecheck.ps1, c:\programdata\wuhelper.exe
Registros de Evidencia (Log_IDs): EVT-00519 a EVT-00564 (8 eventos, 6 en Informational)
Análisis Forense Detallado: Tras una sesión iniciada por CORP\helpdesk (Event ID 4624, 'Informational'), se registró la creación de una tarea programada (Event ID 4698) y la instalación de un servicio de sistema (Event ID 7045). Con posterioridad, el binario implantado se ejecutó de forma periódica cada pocos minutos (Eventos 4688 rotulados con severidad 'Informational' en el SIEM).
Plan de Contención y Remediación Paso a Paso:
1. Detener y eliminar el servicio no autorizado y desregistrar la tarea programada en APP-SRV01.
2. Aislar y extraer hashes forenses de los binarios implantados (c:\programdata\updatecheck.ps1, c:\programdata\wuhelper.exe) antes de su desinfección.
3. Auditar los privilegios de administración local de CORP\helpdesk sobre servidores de producción.

```
Playbook CLI / Regla de Contención:
Get-Service *Update* | Stop-Service -Force; Get-ScheduledTask | Where-Object { $_.TaskPath -like '*Windows*' -and
$_.Actions.Execute -like '*updatecheck*' } | Unregister-ScheduledTask -Confirm:$false
```

[INC-06] Explotación de Servidor Web IIS, Webshell ASPX y Ejecución Remota de Comandos (RCE) — RIESGO ALTO (9.8 (Crítico))

Ventana de Tiempo: 2026-10-23 12:10:00 a 12:15:00 (5 min) | **Kill Chain:** Reconnaissance -> Exploitation -> Persistence (Webshell) -> Execution (RCE)
Activos Comprometidos: WEB-01 (Servidor Web Público) | **Cuentas:** IIS APPPOOL\DefaultAppPool
Mapeo MITRE ATT&CK: T1190 (Exploit Public-Facing Application), T1505.003 (Server Software Component: Web Shell), T1059.003 (Windows Command Shell)
Indicadores de Compromiso (IoCs): IP Atacante: 192.0.2.91 | Host: WEB-01 | Comando RCE: cmd.exe /c whoami
Registros de Evidencia (Log_IDs): EVT-00571 a EVT-00599 (22 eventos)
Análisis Forense Detallado: Entre las 12:10:00 y las 12:15:00 UTC, la IP 192.0.2.91 sondeó endpoints sensibles provocando múltiples errores HTTP (404/500) antes de acceder a un script en la ruta de subidas con código 200. A continuación, el proceso worker bajo 'IIS APPPOOL\DefaultAppPool' instanció directamente un intérprete de comandos ejecutando 'cmd.exe /c whoami' (Event ID 4688), evidenciando la explotación de una vulnerabilidad de subida de archivos arbitraria.
Plan de Contención y Remediación Paso a Paso:
1. Aislar WEB-01 en la DMZ y eliminar cualquier archivo no autorizado en los directorios de subidas web.
2. Deshabilitar los permisos de ejecución de scripts (Handler Mappings) en directorios estáticos de subida de archivos.
3. Bloquear la IP atacante 192.0.2.91 en el Web Application Firewall (WAF) y perimetral.

```
Playbook CLI / Regla de Contención:
Get-ChildItem 'C:\inetpub\wwwroot\uploads\*' -Include *.aspx,*.php,*.jsp | Remove-Item -Force; New-NetFirewallRule
-DisplayName 'Block_WebAttacker_192.0.2.91' -Direction Inbound -RemoteAddress 192.0.2.91 -Action Block
```

[OBS-01] Brechas de Visibilidad SIEM, Eventos Críticos en 'Informational' y Falta de Normalización — RIESGO MEDIO (6.5 (Medio - Riesgo Operativo SOC))

Ventana de Tiempo: 2026-10-23 07:46:07 a 13:44:06 (Ventana completa del dataset) | **Kill Chain:** Defense Evasion -> SIEM Telemetry Blindspots -> Asset Fragmentation
Activos Comprometidos: Fragmentación de Hostnames: 91 vs 30 registros | **Cuentas:** Cuentas Duales: 76 vs 24 registros
Mapeo MITRE ATT&CK: T1562 (Impair Defenses / Suboptimal SIEM Severity Rules & Asset Naming)
Indicadores de Compromiso (IoCs): 12 eventos críticos clasificados como Informational en el SIEM
Registros de Evidencia (Log_IDs): 12 eventos rescatados por correlación multi-etapa SOC Nivel 2
Análisis Forense Detallado: La correlación SOC L2 rescató 12 eventos etiquetados como 'Informational' que evidencian el éxito de las etapas de intrusión. Adicionalmente, se detectó falta de normalización en los agentes de ingesta (inconsistencias en nombres de servidores y duplicidad de cuentas de servicio), lo que fragmenta las alertas y burla las correlaciones automáticas del SIEM de Nivel 1.
Plan de Contención y Remediación Paso a Paso:
1. Implementar reglas de detección Sigma para elevar a severidad High la creación de procesos en rutas temporales y logons anómalos.
2. Normalizar la configuración de recolección de logs en controladores de dominio para unificar nombres de host.
3. Auditar la taxonomía de cuentas de servicio en Active Directory.

```
Playbook CLI / Regla de Contención:
# Regla Sigma / KQL recomendada: SecurityEvent | where EventID == 4688 and (CommandLine has_any
('C:\\ProgramData\\', 'C:\\Users\\Public\\', '7z.exe', 'tar.exe', 'vssadmin'))
```

SECCIÓN 5 — INGENIERÍA DE DETECCIÓN: LOLBAS, GTFOBINS Y REGLAS SIGMA, YARA & YARA-X

Para erradicar la evasión basada en binarios nativos (*Living Off The Land*) y corregir los 12 falsos negativos registrados bajo severidad *Informational* (OBS-01), se documenta la matriz de correlación contra **LOLBAS** (https://lolbas-project.github.io/) y **GTFOBins** (https://gtfobins.org/), seguida de las reglas de detección para SIEM (**Sigma**) y EDR/DFIR (**YARA Clásico** y **YARA-X en Rust**):

Binario / Utilidad	Catálogo	Incidente (Log_IDs)	Comando Detectado en Telemetría SIEM	MITRE ATT&CK / Referencia Oficial
vssadmin.exe	LOLBAS	INC-03 (EVT-00314)	vssadmin.exe delete shadows /all /quiet	T1490 (Inhibit System Recovery) | https://lolbas-project.github.io/lolbas/Binaries/Vssadmin/ | https://gtfobins.org/
tar.exe (bsdtar)	LOLBAS + GTFOBins	INC-02 (EVT-00232)	tar.exe -a -c -f C:\Temp\finance.zip C:\Temp\reports	T1560.001 (Archive via Utility) | https://lolbas-project.github.io/lolbas/Binaries/Tar/ | https://gtfobins.org/gtfobins/tar/
7z.exe / 7z	GTFOBins + Utility Abuse	INC-04 (EVT-00428 (Oculto en Informational))	7z.exe a C:\Users\Public\archive.7z C:\Legal*.docx	T1560.001 (Archive via Utility) | https://lolbas-project.github.io/ | https://gtfobins.org/gtfobins/7z/

Binario / Utilidad	Catálogo	Incidente (Log_IDs)	Comando Detectado en Telemetría SIEM	MITRE ATT&CK / Referencia Oficial
powershell.exe	LOLBAS	INC-02, INC-03 (EVT-00198, EVT-00207, EVT-00235, EVT-00280)	powershell.exe -NoProfile -EncodedCommand <base64_redacted>	T1059.001 (PowerShell), T1027 (Obfuscated Files) | https://lolbas-project.github.io/lolbas/Binaries/Powershell/ | https://gtfobins.org/
schtasks.exe	LOLBAS	INC-05 (EVT-00523)	Tarea programada \Microsoft\Windows\UpdateCheck -> C:\ProgramData\wuhelper.exe	T1053.005 (Scheduled Task/Job: Scheduled Task) | https://lolbas-project.github.io/lolbas/Binaries/Schtasks/ | https://gtfobins.org/gtfobins/crontab/
sc.exe (Service Control)	LOLBAS	INC-05 (EVT-00524, EVT-00528..00564 (5x Info))	Servicio WinUpdateHelper -> C:\ProgramData\wuhelper.exe	T1543.003 (Create or Modify System Process: Windows Service) | https://lolbas-project.github.io/lolbas/Binaries/Sc/ | https://gtfobins.org/gtfobins/systemctl/
net.exe	LOLBAS	INC-02 (EVT-00214)	net.exe view \\FS-SRV01	T1135 (Network Share Discovery) | https://lolbas-project.github.io/lolbas/Binaries/Net/ | https://gtfobins.org/
cmd.exe / whoami.exe	LOLBAS + GTFOBins	INC-06 (EVT-00571, EVT-00599)	cmd.exe /c whoami (invocado desde /uploads/test.aspx?cmd=whoami)	T1505.003 (Web Shell), T1059.003 (Windows Command Shell) | https://lolbas-project.github.io/lolbas/Binaries/Cmd/ | https://gtfobins.org/gtfobins/sh/

ANEXO DE REGLAS DE PRODUCCIÓN — SIGMA (.YML) & YARA-X NEXT-GEN RUST (.YARX)

Regla Sigma SIEM (.yml) — LOLBAS & Informational

```
title: SOC L2 - Abuso de LOLBAS para Staging, Ransomware VSS y
Persistencia
id: 8f4b2c10-9d3a-4e7b-b122-6c9a0e54f201
status: production
description: >
Detecta la ejecución de binarios LOLBAS/GTFOBins observados en
los incidentes INC-02,
INC-03, INC-04, INC-05 e INC-06, incluyendo aquellos
etiquetados erróneamente como
Informational por el SIEM (EVT-00428 7z.exe y EVT-00528..00564
wuhelper.exe).
author: JEV Cyber Command OS (SOC Nivel 2)
date: 2026/10/23
references:
- https://lolbas-project.github.io/lolbas/Binaries/Vssadmin/
- https://lolbas-project.github.io/lolbas/Binaries/Tar/
- https://gtfobins.org/gtfobins/7z/
logsource:
category: process_creation
product: windows
detection:
selection_vss_ransomware:
EventID: 4688
CommandLine|contains|all:
- 'vssadmin'
- 'delete'
- 'shadows'
selection_lolbas_archivers:
EventID: 4688
CommandLine|contains:
- 'tar.exe -a -c -f C:\Temp\finance.zip'
- '7z.exe a C:\Users\Public\archive.7z'
- 'C:\Users\Public\'
- 'C:\Temp\'
selection_encoded_powershell:
EventID: 4688
CommandLine|contains:
- '-EncodedCommand'
- '-enc '
selection_rogue_service_binary:
EventID: 4688
CommandLine|contains: 'C:\ProgramData\wuhelper.exe'
selection_iis_webshell_rce:
EventID: 4688
User|contains: 'DefaultAppPool'
CommandLine|contains: 'cmd.exe /c whoami'
condition: 1 of selection_*
falsepositives:
- Tareas administrativas legítimas debidamente firmadas y fuera
de rutas públicas
level: critical
tags:
- attack.impact
- attack.t1490
- attack.collection
- attack.t1560.001
- attack.persistence
- attack.t1543.003
- attack.t1505.003
```

Regla YARA-X Rust (.yarx — VirusTotal Engine)

```
REGLAS YARA-X (.yarx) — MOTOR NEXT-GEN EN RUST (VIRUSTOTAL)
Sintaxis estricta compatible con `yr scan` (YARA-X CLI / Rust
Engine)
import "pe"
rule YARAX_SOC_L2_MultiIncident_Artifact_Detector
{
meta:
engine = "YARA-X (VirusTotal Rust Engine >= 0.10)"
author = "JEV Cyber Command OS - SOC Nivel 2"
incidents_covered = "INC-02, INC-03, INC-04, INC-05, INC-06"
lolbas_catalog = "https://lolbas-project.github.io/"
gtfobins_catalog = "https://gtfobins.org/"
tlp = "AMBER+STRICT"
strings:
$persist_bin = "C:\ProgramData\wuhelper.exe" ascii wide nocase
$persist_svc = "WinUpdateHelper" ascii wide
$persist_task = "\Microsoft\Windows\UpdateCheck" ascii wide
$lolbas_vss =
/vssadmin(\.exe)?\s+delete\s+shadows\s+\/all\s+\/quiet/i
$stage_finance = "C:\Temp\finance.zip" ascii wide nocase
$stage_legal = "C:\Users\Public\archive.7z" ascii wide nocase
$target_budget = "Budget2027.xlsx" ascii wide nocase
$webshell_uri = "/uploads/test.aspx" ascii wide nocase
$webshell_cmd = "cmd.exe /c whoami" ascii wide nocase
$c2_legal_ip = "198.51.100.88:443" ascii wide
$c2_fin_ip = "203.0.113.88:443" ascii wide
condition:
(
pe.is_pe and
(
$persist_bin or
($persist_svc and $persist_task)
)
)
or any of ($lolbas_vss, $stage_finance, $stage_legal,
$target_budget)
or ($webshell_uri and $webshell_cmd)
or any of ($c2_legal_ip, $c2_fin_ip)
}
```